GROUNDED DI LLC

Salesforce Agent Fabric Control Audit

Independent Public Research Edition
Adversarial documentation, source and local verification review

MODEL WALLETS / KILL SWITCH / TERRAFORM / EVIDENCE

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Publication note and evidence ceiling

Grounded DI LLC prepared this independent public-source engineering review using historically pinned vendor documents, public source code and isolated local verification. It is **not sponsored, endorsed, authorized or certified** by Salesforce or MuleSoft. The public research edition is dated 27 October 2026.

> **THE GOVERNING DISTINCTION**
> Documentation and local helper behavior can be verified without demonstrating a hosted Agent Fabric production failure. This report contains no claim of a customer incident, successful containment bypass, real spending overrun or product-wide security verdict.

The underlying audit and verification records are privately retained by Grounded DI LLC. This PDF is a public analytical record, not a complete executable replay bundle. Source links identify publicly accessible vendor material; no private audit ZIP or local test harness is distributed.

Publication method. Vendor descriptions are distinguished from code inspections, local executions and proposals. The historical audit originally recorded twelve Python source checks and a blocked Go run. This publication review separately reproduced the source checks, the supplement's verifier edge case and nine isolated Go helper tests; those new executions are identified in the relevant chapter rather than retroactively attributed to the original audit.

The book is organized as an adversarial record: precise control or promise, evidence, competing interpretation, boundary, and decisive next test. A reasonable alternative interpretation is included when it affects the proof; it is not a license to reword supported criticism into a generic recommendation.

Evidence term	Meaning in this report
DOCUMENTED	An attributable statement in an identified vendor source; not directly measured here.
SOURCE-SUPPORTED	A proposition visible in pinned source code; runtime layers may differ.
OBSERVED	An actual local test result or state transition in the named execution environment.
UNRESOLVED	The available evidence cannot settle the behavior or breadth of a claim.
NOT EXECUTED	A proposed test, deployed product behavior or interaction not performed.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Contents

Publication note and evidence ceiling 2
Contents 3
Executive findings 4
Scope, source identity and test boundaries 5
F1 | The budget ceiling is not a zero-overshoot guarantee 6
F2 | Unpriced models and fallback alter the cap 7
F3 | The kill-switch stopping boundary 8
F4 | Detection, identity and policy placement 9
F5 | Terraform policy validation is narrower than its field schema 10
F6 | Audit-log visibility is not retention proof 11
F7 | Vendor-reported historical corrections 12
Grounded DI self-audit | A green verifier with a blind spot 13
Execution record | What actually ran 14
Authorized validation matrix 15
Engineering conclusions and open questions 16
Source ledger and attribution 17
Publication integrity and release boundary 18

READING PATH
Begin with the executive evidence map, then the six control investigations. The later self-audit chapter explains why an initially green integrity check was insufficient. The appendices identify source revisions and independent local test boundaries.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Executive findings

The most material discrepancy is a **budget guarantee mismatch**, not a measured cost incident. Salesforce advertises Model Wallet hard limits that stop requests before costs exceed budget, while MuleSoft's operating text says budgets are approximate and usage may briefly exceed the limit. Both refer to the same named capability. [S01–S03]

6	16/16	9/9	0
substantive finding families	pinned upstream blobs matched	isolated local Go tests passed	hosted Agent Fabric runtime tests

Finding	Disposition	What the evidence permits
F1 Budget ceiling	DOCUMENTED GAP	Hard-limit marketing wording versus documented approximate threshold and brief overshoot; no measured charges.
F2 Pricing / fallback	DOCUMENTED CONDITION	Missing prices register zero for spend-based budgets; fallback can change the charged route.
F3 Kill switch	SCOPE UNRESOLVED	Protected model-proxy blocking is documented; broad network/credential/identity containment not traced.
F4 Detection / identity	CONFIGURATION DEPENDENT	No-rule detectors do nothing; claim selectors and proxy placement determine documented scope.
F5 Terraform helper	LOCAL SOURCE + TEST	Known-schema checks omit declared type/range/enum constraints in tested helper; server not tested.
F6 Audit evidence	RETENTION UNRESOLVED	A 90-day security UI view does not establish immutable audit-log retention.

INDEPENDENT AUDIT OF THE AUDITOR

The supplied verifier rejected ordinary mutations but incorrectly accepted an unlisted nested file named MANIFEST.json. The publication review reproduced the behavior, separately verified the supplied exact ZIP inventory, and preserved this adverse Grounded DI result.

A September 2026 MuleSoft release note also documents fixes to policy-application and wallet-display issues. Those are vendor-reported historical fixes, not presently reproduced failures. [S10]

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Scope, source identity and test boundaries

The baseline is October 27, 2026. The source investigation selected pinned revisions from the MuleSoft documentation repositories, an Anypoint Terraform provider, gateway documentation and a demo repository. The public announcement and product page were accessed as live web pages; they are not commit-pinned snapshots. Readers must not conflate a current web page with the code frozen at a historical revision. [S01–S13]

Evidence surface	What was done	What was not done
Documents	Read pinned Model Wallet, kill-switch, pricing, cost and gateway instructions.	No enterprise tenant configuration or vendor contract was inspected.
Public code	Compared sixteen captured Git files with their pinned upstream Git blob identities.	No enforcement-engine source or full Terraform framework run was established.
Local controls	Replayed 12 Python source tests, 9 isolated Go helper tests and synthetic verifier mutations.	No requests to Salesforce models, proxies, agents or billing services.
Historical corrections	Kept original Go BLOCKED result and subsequent separate replay evidence distinct.	No retrospective claim that the historical Go runner succeeded.

A Git blob match verifies byte identity against the referenced Git object at the stated commit. It does not prove the published documentation is complete, that a hosted configuration follows it, or that an unsigned local receipt authenticates the producer. The captured source files were independently matched against GitHub in this publication review; all 16 expected blob identifiers matched.

Local Go execution used Go 1.23.2 and an inert compile-time client stub so the original public helper could run without network access. Terraform plan and apply were **not** run. The validation tests do not import or execute the Agent Fabric kill-switch engine. The source-controlled helper file was copied byte-for-byte into a disposable test environment.

AVAILABILITY AS ANNOUNCED

Salesforce identified the existing Agent Kill Switch, Model Wallet, FinOps Dashboard and Cost Optimization Policies as generally available on October 27; the triggered-agent kill switch and generally available Agent/API Evals were scheduled for January 2027. These are vendor announcements, not independently verified entitlement or deployed-release claims. [S01]

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F1 | The budget ceiling is not a zero-overshoot guarantee

Control / promise. The Salesforce announcement describes hard Model Wallet spending limits that stop requests before costs exceed a budget. The pinned MuleSoft wallet instructions say a model proxy blocks further requests to a provider after the budget is reached, but describe enforcement as approximate rather than a real-time hard cutoff, allowing a brief exceedance. The pinned cost guide repeats that qualification. [S01–S03]

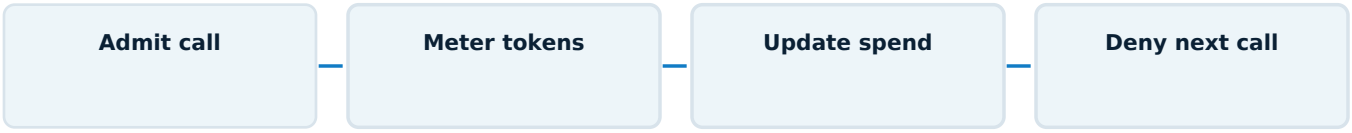
Documented discrepancy. A hard block at some point after a metering threshold is not equivalent to a mathematically non-exceedable ceiling. Both can be called a limit in operational speech, but they imply different guarantees to a budget owner. The documents use the same Model Wallet capability name. The broader announcement language cannot by itself establish a strict real-time cutoff.

What the documents do not quantify. Neither a bound on allowed overshoot nor the treatment of simultaneous requests, already-admitted calls, delayed usage settlement, model-specific price revisions, failed/retried requests or third-party billing reconciliation is established in the reviewed excerpts. No actual model request, invoice or budget event was generated in this audit.

The strongest charitable reading is that hard means *eventually enforced by a deny decision* while the technical documentation discloses an accounting delay. That could be Salesforce's intended meaning. It does not satisfy a reader who interprets hard as no post-threshold spend, and it leaves an enterprise procurement requirement unresolved.

The correct engineering question is not whether the word hard is rhetorically defensible; it is whether an organization can compute its maximum possible financial exposure before submitting work. That requires observable admission, usage settlement and blocking semantics.

Exhibit 01 / Simplified conceptual budget boundary



Illustrative stages only - not an observed product trace

F1 DISPOSITION
DOCUMENTED GUARANTEE GAP. The public language is broader than the technical caveat. No real-world overrun, breach or deployment failure was measured.

Decisive test design — NOT EXECUTED. Set a synthetic provider budget under authorization. Submit sequential and burst-concurrent traffic immediately before the threshold. Preserve request-admission order, model responses, proxy counters, effective price configuration and actual upstream charges. Repeat with retries, streaming and a delayed completion. Report maximum observed overshoot under an explicit concurrency bound, not a single anecdotal figure.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F2 | Unpriced models and fallback alter the cap

Control / promise. Wallets associate spend or token limits with a caller and a provider over a period. The model-pricing instructions explicitly state that models without configured cost contribute zero to spend-based tracking and wallet budgets, while token-based budgets continue counting their tokens. [S02–S04]

Operational consequence. A dollar limit based on administrator-supplied prices is only complete for requests attributed to priced models and traffic crossing the governed model proxy. A zero recorded spend for an unpriced model is not evidence that the underlying provider charges nothing. It is a limitation of the declared tracking input.

The wallet instructions also describe provider-scoped exhaustion: once the budget for provider A is reached, the proxy can route to another model if a fallback is configured. This may be a deliberate resilience design. It does not establish that a single wallet budget controls all alternative providers or that a separately configured organization-wide cap exists. [S02]

Scenario	Documented accounting	Question not settled
Priced model	Dollar tracking uses configured per-model costs.	Does it reconcile to actual billed units/discounts?
Unpriced model	Spend-based budget treats usage as zero; tokens remain countable.	Is an unpriced model blocked elsewhere by policy?
Fallback provider	Next configured route may receive request after provider limit.	Are cumulative and per-provider ceilings jointly applied?
Bypassed proxy	Cost guide excludes traffic that does not reach Model Proxy.	Are other governance routes instrumented?

Strongest alternative interpretation. Administrators are told to set model prices and can use token-based budgets. Provider-level budgets can be intentionally independent. Those facts limit the claim to price-completeness and route-coverage conditions; they do not eliminate the need for an enterprise aggregate policy if that is what the buyer expects.

Decisive test design — NOT EXECUTED. Compare identical model calls with a valid price, missing price and changed price. Verify token versus dollar counters, denial timing and downstream invoices. Exhaust provider A with no fallback, then with a budgeted provider B, then with B lacking a corresponding budget. Reconcile permitted egress with all covered and uncovered usage.

F2 DISPOSITION
DOCUMENTED LIMITATION. Missing pricing can make chargeable usage invisible to a spend-based wallet calculation. No unlimited charges or bypass of the hosted service were demonstrated.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F3 | The kill-switch stopping boundary

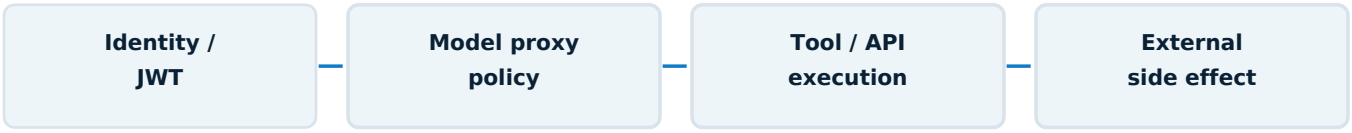
Control / promise. The pinned operational instructions describe two cooperating policies applied to protected model proxies: Rogue Agent Detection flags an agent for review, and Agent Kill Switch blocks the identified agent at those proxies after containment. The instructions require validated JWT claims and matching identity selectors. [S05]

The live Agent Governance page makes a materially broader representation: the kill switch acts across network, credential and identity layers simultaneously, cutting the agent off from what it could reach. The operational guide reviewed in this audit does not trace every mechanism needed for that outcome. [S06]

Documented versus unresolved. The named proxy policy is an observable configuration and access-control surface in the documentation. It does not by itself establish that a direct API route, a second proxy without the policy, a cached credential, a queued worker, an in-flight tool call or an already completed irreversible side effect is interrupted. Other control layers may exist; the audit did not test or disprove them.

Timing is essential. Blocking the next model request can be successful while an already authorized purchase, message or file mutation completes downstream. Consequently, an enterprise definition of kill must name the exact stages it stops: admission, execution, credential use, retries, scheduled work and external side effects.

Exhibit 02 / A stop decision has more than one boundary



Each stage requires a separate observable stop guarantee

Boundary	What would establish effectiveness
Protected proxy	Subsequent requests from the quarantined identity are denied with a policy decision.
Second route	Every intended protected entry point sees the same quarantine state and identity.
External credential	Direct outbound use is rejected after actual revocation/expiry at the relevant service.
In-flight / queue	Delayed, retried and already-admitted work reaches the documented stop state.
Durable effect	No post-quarantine externally committed effect occurs within the specified guarantee.

F3 DISPOSITION
PROXY BLOCKING DOCUMENTED; GENERAL CONTAINMENT SCOPE UNRESOLVED. Neither complete containment nor a bypass is proven.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F4 | Detection, identity and policy placement

Control / promise. The policy instructions require an Agent Identity Selector based on validated JWT claims, the same selector on detection and kill-switch policies, and placement of both policies on each model proxy intended for protection. The guide explicitly says that a detector with no rules forwards requests without detecting anything. [S05]

That no-rule behavior is not itself a defect. It is a concrete configuration state with no detection. A production assurance program that merely confirms installation of a policy, rather than active rules and end-to-end identity consistency, can therefore report nominal coverage without demonstrating a working detector.

Observed boundary. No UI form, claim parser, malformed JWT, policy compiler, deployment-time check, detector inference service or quarantine persistence system was exercised. The guide states that detection adds inference calls, which creates an additional operational dependency and potential incremental cost. Whether the UI prevents empty rules or selector mismatches was not measured.

Strongest defense. Administrators may deliberately configure a nonblocking detector; deployment tooling may constrain mismatched selectors or empty policies. The documented behavior should be judged against the chosen organizational policy, not against an invented universal requirement that every configured detector block requests.

Synthetic case	Measurement required	Status
No active detection rule	Policy accepts/rejects configuration; actual flag count.	NOT EXECUTED
Identity selector mismatch	Detected identity compared with denied identity.	NOT EXECUTED
Missing/expired JWT claim	Validation, attribution, error and deny/allow behavior.	NOT EXECUTED
Second unprotected route	Positive and negative proxy coverage test.	NOT EXECUTED
Inference unavailable	Detection fail-open/fail-closed behavior and audit event.	NOT EXECUTED

F4 DISPOSITION

CONFIGURATION-DEPENDENT CONTROL. The guide establishes meaningful prerequisites and one explicit no-rule outcome. A hosted enforcement conclusion would require authorized execution.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F5 | Terraform policy validation is narrower than its field schema

Control / promise. The pinned generic Terraform policy resource describes validation of known policy configurations at plan time. Its inspected resource implementation calls the configuration validation helper along the Create and Update paths; that file does not visibly provide a ValidateConfig or ModifyPlan method. Other framework components could perform separate validation, and Terraform itself was not executed. [S07]

Helper contract and code. The pinned **ValidatePolicyConfiguration** helper returns no validation errors for unknown policy schemas. For known schemas, it checks required-field presence and unrecognized field names. A related field specification declares Type, Min, Max, Enum and ElemEnum, but the inspected helper does not evaluate those constraints. Public source tests intentionally establish the unknown-schema skip behavior. [S08–S09]

Fresh local recheck. Six supplied audit-authored Go tests passed against the unchanged pinned helper with an inert client stub. Three additional isolated cases, authored separately from the four supplied files and rerun for this publication review, also passed: a value above a declared maximum, a value outside a declared string enum, and an element outside a declared array enum produced no helper errors. These outcomes concern that function, not a deployed policy.

Case exercised	This helper returned	Limit
Known JWT required field absent	A required-field error	Expected local presence enforcement
Known JWT unexpected key	An unknown-field error	Expected local name enforcement
Unknown policy asset	No schema errors	Intended skip, not platform acceptance
JWT field with wrong type	No schema errors	No type validation in this helper
Time period above declared max	No schema errors	No maximum check in this helper
Invalid authType enum	No schema errors	No enum check in this helper
Unknown PII entity enum value	No schema errors	No element-enum check in this helper

The source-supported gap has two levels: (1) the generic provider description creates a plan-time validation expectation not established by the visible create/update call sites, and (2) this particular helper performs less validation than its schema field metadata could suggest. Neither proposition demonstrates actual plan-time failure, server acceptance or an Agent Fabric exploit.

> **CRITICAL ARCHITECTURAL BOUNDARY**
> The Anypoint Terraform configuration provider is not the Salesforce Agent Fabric enforcement engine. Local helper acceptance is not hosted gateway acceptance.

Decisive next test — NOT EXECUTED. Under an authorized isolated Terraform configuration, compare validate, plan and apply for missing fields, invalid JSON, wrong types, out-of-range values, enums and unknown policy schemas. Capture full provider diagnostics, plan/apply phase, mock API requests and server responses. Test framework-level and policy-specific checks separately.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F6 | Audit-log visibility is not retention proof

Control / promise. The pinned operational guide says the Security page presents flagged and reviewed agents from a 90-day lookback. It also describes audit records for quarantine and reactivation actions, including agent identifier, initiating user, timestamp and environment. [S05]

Unresolved boundary. A security UI time window is not a retention SLA for the underlying audit store. The reviewed sources do not establish whether evidence is append-only, independently tamper-evident, available through an export API, or preserved through network partition, retry, backend outage or administrative deletion. Nor do they show the time ordering of every detector decision, proxy deny and external side effect.

The strongest alternative is that separate logging products, organization-level retention settings or contracts may provide these guarantees. Because those sources were outside this audit, the correct disposition is a missing evidence requirement, not an assertion that logs are discarded after 90 days.

Decisive test — NOT EXECUTED. Quarantine and restore a synthetic identity while recording causal event IDs and policy version. Restart the affected telemetry component, interrupt the sink and restore it. Compare records in the UI, query/export interfaces and durable store after the UI lookback. Verify event completeness, order, privilege-based deletion, retention and disposition.

> **F6 DISPOSITION**
> UNRESOLVED. The 90-day UI lookback and named action fields are documented. Retention duration, immutability, completeness and failure behavior are not established.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

F7 | Vendor-reported historical corrections

The MuleSoft release notes record a September 7, 2026 fix (W-24026346) involving previously silent failure when applying agent optimization policies. The same period includes wallet visibility and display-related corrections; the August 31 notes announce model-wallet cost-budget and rogue-agent containment capabilities. These public entries are historically useful for selecting regression cases. [S10]

A release-note assertion is a vendor report of a fix, not an independent reproduction of the earlier defect or a guarantee the fix behaves correctly for every customer. The current publication does not present those historical items as live vulnerabilities. Likewise, a public Agent Fabric demo README describes a reference architecture; it is not the implementation of the hosted enforcement engine. [S11]

Historical source	Engineering use	What not to infer
Sept 7 release notes	Ask for regression evidence on silent policy-apply failures.	That current policy application silently fails.
Wallet visibility fixes	Test environment filtering and wallet discovery.	That current wallet routing is incorrect.
Aug 31 feature notes	Context for the public operating guide.	That every tenant had identical entitlement.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Grounded DI self-audit | A green verifier with a blind spot

Original integrity record. The supplied ZIP's SHA-256, manifest SHA-256, exact archive member count and 29 listed member hashes matched the unsigned detached receipt. The standalone executive PDF matched the copy in the ZIP. Ordinary verifier tests also rejected a modified file, a deleted file and an unlisted ordinary extra file. Those are real passing tests, not claims of independent authentication.

Supplementary counterexample. An adversarial synthetic mutation added an unexpected nested file with the basename **MANIFEST.json**. The extracted-package verifier incorrectly reported success because its inventory exclusion was applied to that basename wherever it appeared, rather than solely to the root manifest. The supplemental record calls this an adverse verifier result; the present publication review reproduced it in a fresh temporary extraction.

THE CONSEQUENCE
The original extracted-package verifier cannot by itself establish exact file membership for every possible path. A separate exact ZIP inventory comparison accounted for all 30 entries in the supplied original and passed. Those statements can both be true.

Mutation against temporary copy	Verifier behavior	Adversarial assessment
No mutation	PASS	Expected: clean package accepted.
Modify listed source	MISMATCH / reject	Expected: listed bytes changed.
Delete listed source	MISSING / reject	Expected: listed member absent.
Add arbitrary unlisted file	EXTRA / reject	Expected: membership violation.
Add nested MANIFEST.json	PASS / accepted	DEFECT: unlisted nested file ignored.

Counterevidence retained. The verifier defect does not imply the original ZIP contains an unnoticed nested manifest; the independent exact ZIP comparison found no unlisted members. It does mean that the verifier's passing statement, taken alone, overclaims its exclusion behavior. The defect is in Grounded DI's local audit packaging, not Salesforce.

This self-test illustrates the same evidentiary principle applied to the vendor: an accepted test case and a broad operational guarantee are different things. A verifier can correctly reject several mutations and still have a specific blind spot.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Execution record | What actually ran

The historical audit and the present publication review are separate execution stages. Test counts below refer to different populations and must never be pooled as a product-control coverage percentage.

Stage	Count / disposition	Provenance and meaning
Original source check	12 PASS	Historical Python source snapshots and evidence anchors, including a synthetic appended-byte hash control.
Original Go runner	BLOCKED	Historical environment had no Go compiler; no Go tests executed there.
Supplement replay	10 labeled PASS	Receipt/inventory checks and five mutation cases; nested-manifest PASS denotes successful reproduction of undesirable acceptance.
Current source rerun	12 PASS	Fresh Python test execution, not Agent Fabric runtime tests.
Current Go rerun	6 PASS	Original audit-authored Go cases against the unchanged pinned helper and isolated client stub.
Current additional Go	3 PASS	Separately authored max/enum/element-enum cases; same pinned helper and no server.
Upstream identity check	16/16 matched	Pinned GitHub Git blob identifiers independently retrieved and compared.
Hosted product/Terraform	NOT EXECUTED	No Salesforce tenant, billing event, hosted proxy, Terraform plan or apply.

Current local environment. Go 1.23.2 on Linux; Python 3.13.5. The original source code was copied byte-identically into an isolated temporary Go module with a client stub disabling construction of the network client. The representative command was **go test -count=1 -v ./internal/client/apimanagement**, with network module resolution disabled. The 9/9 combined test pass result is an audit-authored unit test population, not a vendor-provided upstream test suite.

Two kinds of pass. A Go test that expects this helper to return no error for an invalid enum passes when the omission is reproduced. Likewise, the nested-manifest regression characterization passes when the old verifier incorrectly accepts the extra file. The test runner's PASS does not transform the observed behavior into correct enforcement.

Supplied supplement limits. The supplement described six pass results from screenshots captured in another Go 1.23.2 environment, but did not contain their complete underlying logs. This publication review performed a new local run, generating its own observed outputs. The present results do not retroactively alter the original historical BLOCKED status.

> **DO NOT AGGREGATE**
> 12 Python evidence checks + 9 Go helper tests + 10 integrity/mutation checks are not 31 independent Salesforce control tests. They have different targets, preconditions and meanings.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Authorized validation matrix

The following work is recommended for an authorized isolated Salesforce/MuleSoft environment. Nothing in this matrix was executed against a hosted tenant during this audit. Each row identifies the measurement required to move a claim beyond documentation or helper-level evidence.

Control / test vector	Evidence to preserve	Pass criterion must be agreed before test
Budget around threshold: single stream, bursts, concurrency	Requested/allowed/blocked calls, usage counter, model invoices, timestamps.	Quantified and contract-consistent maximum overshoot and denial semantics.
Missing model price; changed price	Model price version, token count, spend count, emitted decision.	An explicit outcome when pricing is incomplete, not an inferred zero-cost model.
Fallback across two providers	Route choices, each provider budget, aggregate spend, fallback status.	No claimed aggregate limit is crossed when the intended configuration requires it.
Quarantine across routes	Agent identity, applied policies, route map, before/after denies.	All routes within the declared protection domain deny after containment.
In-flight delayed tool action	Admission, execution, queue, callback and external side-effect record.	Observed cancellation/commit matches the published stop guarantee.
No rule, missing claims, selector mismatch	Configuration validity, detector action and deny logs.	Configured fail-open/fail-closed policy is explicit and consistently enforced.
Terraform malformed known policy	Validate, plan, apply phase logs and mock request/response.	Documented plan-time guarantee is evidenced; server behavior separately recorded.
Logging interrupted during quarantine	Decision IDs, durable exports, timing and recovery events.	Retention and loss behavior matches agreed audit evidence requirements.

A proper exercise also needs negative controls: ordinary allowed traffic should remain allowed, identity scopes should not collide, unaffected providers should remain operational, and failed requests should not be counted as completed side effects without evidence. Test isolation, authorization and evidence retention are essential; the matrix does not request unapproved testing of customer services.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Engineering conclusions and open questions

1. The budget conflict is the clearest public claim to resolve. A buyer requiring a strict non-exceedable dollar ceiling cannot infer that guarantee from the documentation reviewed. The limit may be operationally effective; its permitted overshoot is not bounded by the cited sources. [S01–S04]

2. A kill switch must be defined by its reach. The documented operational policy blocks quarantined identities at protected model proxies. Broader simultaneous network, credential and identity containment requires architectural and in-flight evidence not obtained here. The report preserves both statements rather than treating the operational guide as proof against broader layers. [S05–S06]

3. Configuration completeness is an enforcement precondition. Missing prices can produce zero recorded dollar spend; a no-rule detector can detect nothing; identity selectors and policy placement determine proxy coverage. These are documented choices with important deployment consequences, not observed customer incidents. [S02–S05]

4. Infrastructure tooling is not the product runtime. The pinned Terraform helper checks fewer properties than its field metadata declares, and the local Go tests reproduce that narrow fact. No inference to hosted acceptance, policy bypass or plan-time behavior is warranted. [S07–S09]

5. The auditor has an identified defect too. Grounded DI's old extracted-package verifier missed an unlisted nested manifest file while rejecting ordinary tampering. Reporting that result, and separately validating the actual supplied archive inventory, preserves the distinction between a useful control and a complete guarantee.

> **FINAL SUBSTANTIVE ASSESSMENT**
> This audit identifies documented guarantee gaps, configuration dependencies and a local provider-helper limitation. It does not certify Salesforce controls, report a tested production failure or assign a product-wide security score. The governing next step is a bounded, authorized execution trace with preserved side effects and billing evidence.

The complete private engineering record contains additional test scripts and receipts; they were not supplied as public files with this edition. Grounded DI LLC retains them unchanged. This public book is written to stand on its own as a technically checkable source-linked analysis, with unresolved questions made explicit.

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Source ledger and attribution

Source tags in the body refer to the items below. Vendor documents captured from GitHub are pinned to historical revisions; public website and release-note pages may change. All material source quotations in this book are brief and are presented as paraphrases wherever possible. Git repository contents and their license terms remain with their respective owners.

[S01] Salesforce. Agent Fabric announcement and availability (27 Oct 2026). View pinned/public source

[S02] MuleSoft. Pinned Model Wallet operations and approximate budget enforcement. View pinned/public source

[S03] MuleSoft. Pinned cost-management guide: budgets, proxies and cost coverage. View pinned/public source

[S04] MuleSoft. Pinned model-pricing guide: unpriced-model treatment. View pinned/public source

[S05] MuleSoft. Pinned rogue-agent detection, quarantine and log instructions. View pinned/public source

[S06] MuleSoft. Agent Governance product description (live page, checked 27 Oct 2026). View pinned/public source

[S07] MuleSoft GitHub. Pinned Terraform generic policy resource (schema, create/update). View pinned/public source

[S08] MuleSoft GitHub. Pinned Terraform policy registry and validation helper. View pinned/public source

[S09] MuleSoft GitHub. Pinned upstream tests, including unknown-schema behavior. View pinned/public source

[S10] MuleSoft. Enhanced MuleSoft Experience release notes (historical fixes). View pinned/public source

[S11] MuleSoft GitHub. Pinned public Agent Fabric demo README; not runtime proof. View pinned/public source

[S12] MuleSoft GitHub. Pinned Gateway agent-policy documentation. View pinned/public source

[S13] MuleSoft GitHub. Pinned Agent Fabric overview. View pinned/public source

Pinned commit groups: **docs-general** e1d81f064e2f; **Terraform provider** 3cd00fcbebec; **docs-gateway** 9bfa6b14d8dc; **Agent Fabric demo** 02d82225bfa3. Full commit identifiers appear in the linked source URLs. All sixteen captured source files matched their expected upstream Git blob identifiers in this publication review.

Unpinned marketing claims were checked against the vendor web pages on 27 October 2026. A later change to a live page should not be misread as a change to this historical finding. [S01, S06, S10]

ENGINEERING REVIEW / INDEPENDENT PUBLIC EDITION

Publication integrity and release boundary

Artifact. This PDF is a public research edition derived from a historical private investigation. It was authored without including private source ZIPs, unpublished Grounded DI framework specifications, credentials, private runtime paths or reproducible implementation recipes for the local verifier.

Verification. A separate public release receipt records this PDF's checksum, page count, metadata and rendering inspection, as well as the distinction between archive-consistency verification, local source/helper tests and hosted product execution. Its checksum does not authenticate the author without a separate trusted signature.

Residual limits. No independent legal opinion, patent-clearance determination, third-party certification, hosted budget test, external containment test or Terraform provider plan/apply run is asserted. Public vendor material remains the property of its owners. The underlying original and supplementary private audit archives are not offered as download attachments.

PUBLICATION DECISION

Independent public engineering research. No vendor endorsement or production certification.